

VPC Design

Virtual Private Cloud - A Systems Design Deep Dive

Interview Preparation Guide

Problem & motivation - internals & packet flow - routing decisions - advantages & trade-offs -
failure modes - scaling - security - observability & automation - cost - troubleshooting -
real-world examples

Table of Contents

1. The Problem It Solves	3
2. How It Works Internally	3
3. Traffic Flow, Packet Flow & Routing Decisions	5
4. Advantages & Disadvantages	6
5. Common Failure Modes	6
6. Scaling Considerations	7
7. Security Implications	7
8. Observability, Reliability & Automation	7
9. Cost Considerations	8
10. Troubleshooting Approach	8
11. Real-World Examples & Patterns	9
12. Senior-Level Trade-offs & Talking Points	9
13. Quick Glossary	9

Executive Summary

A Virtual Private Cloud (VPC) is a logically isolated, software-defined network carved out of a cloud provider's shared physical infrastructure. It gives a tenant a private IP address space, full control over subnetting, routing, and traffic filtering, and secure connectivity to the internet, on-premises data centers, and other VPCs - all while appearing, to the tenant, as a dedicated network. This guide covers the problem VPCs solve, how they work internally (control plane vs. data plane, packet flow, routing), trade-offs, failure modes, scaling, security, observability, automation, cost, troubleshooting, and real-world patterns - framed for senior systems-design interviews.

1. The Problem It Solves

Before VPCs, early cloud (e.g., EC2-Classic) placed every customer's instances on a single flat shared network. That model had serious limitations: no network isolation between tenants, no control over IP addressing, no private subnets, and weak ability to model a traditional enterprise network topology in the cloud.

Core needs a VPC addresses

- **Isolation:** Tenants must not see or reach each other's traffic, even though they share the same physical hardware and hypervisors.
- **Address control:** Customers want to choose their own RFC 1918 CIDR ranges (e.g., 10.0.0.0/16) to avoid overlap and integrate with on-prem networks.
- **Segmentation:** Multi-tier apps need public/private/isolated subnets with distinct reachability (web tier exposed, DB tier never directly reachable).
- **Controlled connectivity:** Selective, auditable paths to the internet, on-prem (VPN/Direct Connect), and peer networks.
- **Defense in depth:** Layered filtering via security groups, network ACLs, and routing.

Interview framing

Position the VPC as 'a multi-tenant network virtualization layer that gives each tenant the illusion of a private, fully-controlled network on shared hardware.' Then immediately ask: what isolation guarantees, what scale (IPs, instances, regions), and what connectivity requirements?

2. How It Works Internally

Network virtualization & encapsulation

A VPC is an overlay network. Each instance's virtual NIC has a private IP from the tenant's CIDR, but packets actually traverse the provider's physical (underlay) network. The provider's virtualization layer (e.g., AWS Nitro, a SmartNIC, or a host-level agent) encapsulates each packet - typically in a VXLAN/GENEVE-style header - tagging it with the VPC identity and mapping the virtual destination IP to the physical host that currently runs the target instance.

- A distributed mapping service answers 'which physical host holds virtual IP X in VPC Y?' - this is the

heart of the data plane.

- Encapsulation enforces isolation: a packet tagged for VPC Y can never be decapsulated into VPC Z, so tenants cannot reach each other even on shared wires.
- The mapping is distributed and cached at each host to avoid a central bottleneck.

Control plane vs. data plane

- **Control plane:** Handles API calls (create subnet, attach gateway, modify route table, change security group). It validates, persists desired state, and pushes configuration out to hosts/SmartNICs. It is API-rate-limited and eventually consistent - but NOT in the packet path.
- **Data plane:** Per-packet forwarding, encapsulation, security-group/NACL evaluation, and mapping lookups - executed in hardware/host agents at line rate. Must stay up even if the control plane is degraded.

Key principle

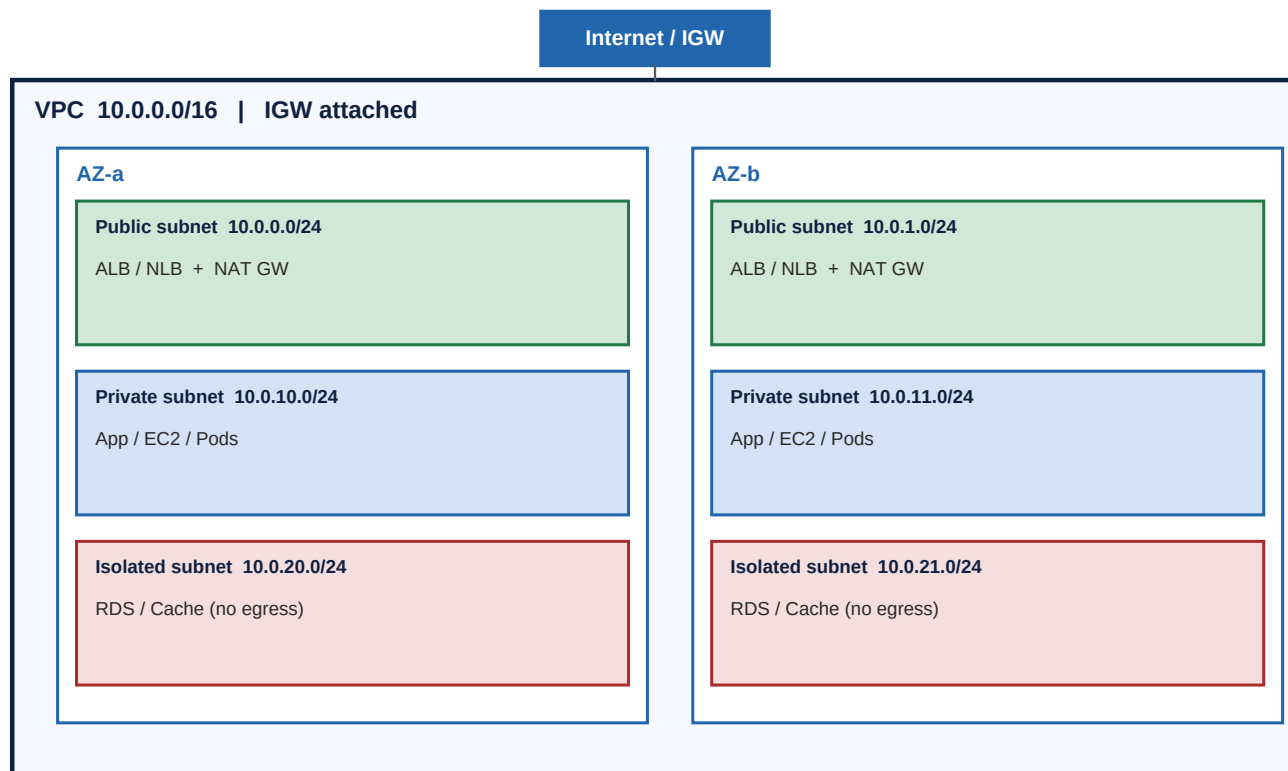
Keep the data plane independent of the control plane. Existing flows should keep forwarding even during a control-plane outage; only new configuration changes should stall. This separation is a recurring senior-interview theme.

Building blocks

Component	Purpose
CIDR / subnets	Private IP space split into per-AZ subnets (public/private/isolated).
Route tables	Per-subnet rules deciding next hop for each destination prefix.
Internet Gateway (IGW)	Horizontally-scaled, HA target enabling public ingress/egress.
NAT Gateway	Lets private subnets reach the internet outbound without inbound exposure.
Security Groups	Stateful, instance-level allow rules (default deny inbound).
Network ACLs	Stateless, subnet-level allow/deny rules (ordered).
VPC Endpoints	Private access to managed services without traversing the internet.
Peering / Transit GW	Connect VPCs to each other and to on-prem at scale.

Reference Architecture (single region, multi-AZ)

The diagram below shows a common production VPC: public subnets hosting internet-facing load balancers and NAT gateways, private subnets hosting application servers, and isolated subnets hosting databases - spread across two Availability Zones for high availability.



Flow: client -> IGW -> public ALB -> private app tier -> isolated DB tier. Outbound from private subnets -> NAT GW (in public subnet) -> IGW. Each subnet has a route table; security groups (stateful) wrap instances, NACLs (stateless) wrap subnets.

3. Traffic Flow, Packet Flow & Routing Decisions

Step-by-step outbound packet (private app -> internet)

- App instance (10.0.10.5) sends a packet to 203.0.113.9 (an external API).
- Security group (egress) is evaluated - stateful, so the return path is auto-allowed.
- Subnet route table: longest-prefix match. 0.0.0.0/0 -> NAT Gateway.
- Packet is encapsulated and forwarded across the underlay to the NAT GW's host.
- NAT GW rewrites source IP to its public/EIP address and tracks the flow.
- Route table at NAT's public subnet: 0.0.0.0/0 -> Internet Gateway.
- IGW performs 1:1 NAT (or passes the already-translated address) onto the internet.
- Return traffic reverses the path; stateful tables permit it without explicit rules.

Routing decision order (mental model)

- 1. Local route (the VPC CIDR) always wins for in-VPC destinations - cannot be removed.
- 2. Most-specific prefix match wins (longest-prefix match).
- 3. Static routes generally preferred over propagated/dynamic for equal prefixes.
- 4. Stateful security groups + stateless NACLs are applied around forwarding.

SG vs. NACL (common gotcha)

Security groups are STATEFUL (return traffic auto-allowed) and instance-scoped with allow-only rules. NACLs are STATELESS (you must allow both directions, including ephemeral ports 1024-65535 for responses) and subnet-scoped with ordered allow/deny. Forgetting ephemeral-port return rules on NACLs is a classic outage.

4. Advantages & Disadvantages

Advantages

- Strong tenant isolation with the flexibility of software-defined networking.
- Full control of addressing, subnetting, routing, and segmentation.
- Layered security (SG + NACL + routing + endpoints) enabling defense in depth.
- Elastic and API-driven - networks become code (IaC), reproducible and auditable.
- Private connectivity to managed services and on-prem without internet exposure.

Disadvantages / costs

- Significant conceptual complexity; easy to misconfigure routing or filtering.
- Provider-specific abstractions reduce portability across clouds.
- Hard limits (CIDR size, route-table entries, peering count) force architecture choices.
- Some components cost real money (NAT GW data processing, cross-AZ traffic, endpoints).
- Non-overlapping CIDR planning across many VPCs/accounts is an ongoing governance burden.

5. Common Failure Modes

Failure	Symptom	Typical root cause
Missing/incorrect route	Timeouts, no reply	0.0.0.0/0 not pointing at IGW/NAT, or route table not associated.
SG too restrictive	Connection refused/hang	Required port/source not allowed inbound.
NACL blocks returns	Intermittent/one-way	Stateless NACL missing ephemeral-port allow.
CIDR overlap	Peering/VPN broken	Overlapping ranges make routing ambiguous.
NAT GW saturation	High latency, drops	Port exhaustion or per-AZ NAT bandwidth limits.
AZ failure	Partial outage	Single-AZ NAT/subnet with no multi-AZ redundancy.
DNS misconfig	Name resolution fails	DNS resolution/hostnames disabled, or resolver rules.
Control-plane lag	Changes not applied	Eventual consistency / propagation delay on rules/routes.

6. Scaling Considerations

- **IP planning:** Pick CIDR blocks large enough for growth but disjoint across VPCs/accounts/regions; reserve space for future subnets and peering.
- **Multi-AZ:** Replicate subnets, NAT, and gateways per AZ; never depend on a single AZ.
- **Connectivity at scale:** Full-mesh peering is $O(n^2)$ and hits limits - move to a hub Transit Gateway / network hub for many VPCs and on-prem links.
- **NAT throughput:** Watch per-NAT bandwidth and source-port exhaustion; scale out per AZ or use NAT instances/fleets for very high egress.
- **Route-table limits:** Aggregate routes (supernetting) to stay within entry limits.
- **Multi-region:** Use separate VPCs per region connected via inter-region peering / global transit; design for latency and data-residency.

Trade-off to verbalize

Peering gives lowest latency and cost for a few VPCs but does not scale operationally; a Transit Gateway centralizes routing (simpler at scale) at the cost of an extra hop, added latency, and a potential blast-radius/bottleneck if not regionalized.

7. Security Implications

- Default deny: start closed, open only what is required (least privilege).
- Tiered subnets: public (LB/NAT only), private (app), isolated (data, no egress).
- Use VPC endpoints / PrivateLink so service traffic never leaves the private network.
- Encrypt in transit (TLS) and rely on encapsulation for tenant isolation - but never treat the network as the only control (assume zero trust).
- Centralize egress and inspection (firewall, IDS/IPS) for auditability.
- Log and alert on SG/NACL/route changes; treat network config as security-sensitive.
- Beware overly broad SG rules (0.0.0.0/0 on management ports) and permissive peering.

8. Observability, Reliability & Automation

Observability

- Flow logs: per-flow accept/reject records for forensics and capacity planning.
- Metrics: NAT bytes/port usage, gateway throughput, packet drops, endpoint errors.
- Path/reachability analyzers to prove (or disprove) that A can reach B and why.
- DNS query logging and traffic mirroring for deep inspection when needed.

Reliability

- Multi-AZ everything; gateways should be horizontally scaled and self-healing.
- Keep the data plane working during control-plane degradation (existing flows survive).
- Health-check and fail over NAT/egress paths; avoid single points of failure.

Automation (network as code)

- Define VPCs/subnets/routes/SGs in IaC (Terraform/CloudFormation/CDK) - reviewable, versioned, repeatable.
- Policy-as-code and pre-deploy checks to catch overly broad rules or CIDR overlaps.
- Automated drift detection so the live network matches the declared state.

9. Cost Considerations

Cost driver	Why it adds up	Mitigation
NAT Gateway	Hourly + per-GB processing on all egress.	VPC endpoints for in-cloud traffic; consolidate egress.
Cross-AZ traffic	Per-GB charge for inter-AZ flows.	AZ-aware routing; keep chatty tiers co-located.
Data transfer out	Internet egress is metered.	CDN/caching; compress; minimize external chatter.
Endpoints	Per-endpoint + per-GB.	Share endpoints; only for high-volume services.
Idle gateways	Hourly even when unused.	Tear down dev/test resources; automate cleanup.

10. Troubleshooting Approach

Work the path methodically, layer by layer, from source to destination:

1. Reproduce & scope: which source, destination, port, protocol? One AZ or all?
2. Routing: does the subnet's route table have a route to the destination (right next hop)?
3. Security groups: inbound on target AND outbound on source allow this flow?
4. NACLs: both directions allowed, including ephemeral ports for return traffic?
5. Gateways: IGW/NAT/endpoint healthy and correctly targeted?
6. DNS: does the name resolve to the expected (private vs. public) address?
7. Evidence: read flow logs (ACCEPT/REJECT) and run a reachability analyzer.
8. Overlap/peering: confirm no CIDR overlap and that routes propagate both ways.

Mnemonic

'Route -> SG -> NACL -> Gateway -> DNS.' Walk these five in order and most VPC connectivity issues fall out quickly.

11. Real-World Examples & Patterns

- **3-tier web app:** Public ALB -> private app subnet -> isolated DB subnet; NAT for outbound updates; multi-AZ throughout.
- **Hub-and-spoke:** Central Transit Gateway connects many application VPCs and on-prem via VPN/Direct Connect, with centralized egress inspection.
- **Shared services VPC:** Common services (CI, logging, DNS, AD) in one VPC consumed by others through peering/PrivateLink.
- **PrivateLink/SaaS:** Expose a service to other VPCs/customers privately without IP overlap concerns or internet exposure.
- **Landing zone:** Multi-account org with standardized VPC blueprints, non-overlapping IPAM-managed CIDRs, and guardrails enforced via policy-as-code.

12. Senior-Level Trade-offs & Talking Points

- Peering vs. Transit Gateway: latency/cost vs. operational scalability and blast radius.
- NAT Gateway vs. self-managed NAT instances: simplicity/HA vs. cost/throughput control.
- Big single VPC vs. many small VPCs: simpler routing vs. blast-radius isolation and limits.
- Network controls vs. zero-trust app-layer auth: never rely on the network alone.
- Centralized egress inspection vs. distributed: visibility/control vs. added hop & cost.
- Eventual consistency of the control plane: design changes to be safe under propagation lag.
- Cost vs. resilience: cross-AZ redundancy improves reliability but increases data-transfer cost.

Whiteboard checklist

(1) Clarify scale & connectivity needs. (2) Draw VPC + multi-AZ subnets (public/private/isolated). (3) Add IGW, NAT, route tables, SG/NACL. (4) Show packet flow in and out. (5) Discuss isolation (encapsulation) and control/data-plane split. (6) Cover failure modes, scaling (TGW), security, observability, and cost trade-offs.

13. Quick Glossary

Term	Meaning
CIDR	Classless Inter-Domain Routing block defining an IP range (e.g., /16).
Underlay / Overlay	Physical provider network vs. virtual tenant network on top.
Encapsulation	Wrapping tenant packets (VXLAN/GENEVE) for isolated transport.
IGW / NAT GW	Internet gateway (in/out) / NAT gateway (outbound-only for private).
SG / NACL	Stateful instance firewall / stateless subnet firewall.
Transit Gateway	Hub that connects many VPCs and on-prem networks.
VPC Endpoint	Private entry to managed services without internet transit.
Flow logs	Per-flow accept/reject records used for audit and debugging.